Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 2.1 / COMPANION WORKBOOK

RMF to ATO

Every RMF step: the lessons, the workspace and the templates

Take the network the Build the Network courses (1.1–1.19) create, the system shown in Inside the Network, through all seven steps of the Risk Management Framework (RMF) to an Authorization to Operate, following NIST SP 800-37 Revision 2 with the April 2016 Joint Special Access Program Implementation Guide (JSIG) mapped in. Each step pairs its lessons with the same task in the ATO Package Builder and its templates from the ATO Template Library: prepare and categorize the system, select and implement its controls, build the Body of Evidence, assess it and plan the fixes in a POA&M, assemble the package for a decision, and keep the authorization current.

MATERIALS EDITION 2.0 / COURSE 2.1

Updated 15 October 2026 · sbd-rmf

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

Table of contents

Read each module alongside the interactive course. Use the record tables to write down what you actually produce — the workbook is your record, not the course.

Before you start

RMF steps, tasks, and outputs

01 RMF roles, steps, and editions

02 Define and register the system

03 Describe and categorize the system

04 Select controls and plan monitoring

05 Implement and document the controls

06 Connect implementation to proof

07 Prepare the assessment

08 Perform and report the assessment

09 Build the plan of action and milestones

10 Assemble the authorization package

11 Support the authorization decision

12 Monitor and maintain authorization

Authorization to Operate package capstone

Evidence starters

Knowledge check answers

Sources

Course review and sign-off

> **HOW TO USE IT** Each module page has the same shape: its RMF step with the NIST SP 800-37 Rev. 2 and JSIG tasks and outputs, three short lessons, a worked example, the practice output, and a record table. Fill the tables from your own records — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

Take the network the Build the Network courses (1.1–1.19) create, the system shown in Inside the Network, through all seven steps of the Risk Management Framework (RMF) to an Authorization to Operate, following NIST SP 800-37 Revision 2 with the April 2016 Joint Special Access Program Implementation Guide (JSIG) mapped in. Each step pairs its lessons with the same task in the ATO Package Builder and its templates from the ATO Template Library: prepare and categorize the system, select and implement its controls, build the Body of Evidence, assess it and plan the fixes in a POA&M, assemble the package for a decision, and keep the authorization current.

Prerequisites

- ☐ Basic security and system administration knowledge. No commercial tool access is required.
- ☐ Your Inside the Network build from Build the Network (courses 1.1–1.19), or the supplied sample records; the samples are enough to complete the course.
- ☐ The governing direction for your practice: NIST SP 800-37 Revision 2 and, for a Special Access Program (SAP) system, the JSIG or successor your program directs. This course uses the public April 2016 JSIG.

What this course covers

- Explain RMF roles and how NIST SP 800-37 Revision 2 and the 2016 JSIG organize the seven steps and their outputs.
- Prepare, categorize and select controls for the Inside the Network system, then implement them and prove each one with indexed evidence.
- Assess the controls, plan every weakness in a POA&M, and take the package through review to an Authorizing Official's decision.
- Keep the authorization current with change analysis, ongoing assessment and reporting, using official templates and practice samples at every step.

Practice artifacts in this course

- System scope record — Agree on the roles, governing direction, mission, boundary, information, early risks, and requirements before the package grows. Module 01 starts it, module 02 completes the Prepare fields, and module 03 adds the categorization basis.
- System registration — Register the system with the office the organization or program designates, so it is known, tracked, and accountable before the package grows. NIST registers in Prepare (P-18); the JSIG in Categorize (Task 1-3).
- System Security Plan — Describe the system and its categorization, record the plan’s approval, and explain how each selected control is implemented.
- Security Controls Traceability Matrix — Record each selected control’s source, tailoring, parameters, allocation, and inheritance, then trace it to implementation, evidence, and results. Started in Select; module 05 adds the as-implemented statements.

© 2026 Secure By Design Team LLC.

- Risk Assessment Report — Record the risks that remain with the selected controls, how likely and harmful each is, and what the assessment must confirm. Drafted in Select as a JSIG Step 2 output; module 08 updates it with assessment results.
- Continuous monitoring strategy — Define what is monitored, how often, by whom, and what triggers action, so the authorization basis stays current. Written in Select (S-5; JSIG Task 2-3) and run in module 12.
- Master evidence index — Make every supporting record retrievable, attributable, current, and traceable to the objectives it supports.
- Security Assessment Plan — Define who assesses, what they receive, and what will be assessed and how, so the results are defensible.
- Security Assessment Report — Record what was assessed, what was observed, the findings and limitations, and the result of any reassessment.
- Plan of Action and Milestones — Turn an open finding into a risk-ranked, resourced, dated plan that the AO can review and use to monitor progress.
- Authorization package manifest — Identify the exact records submitted for the AO’s decision, what each one satisfies (JSIG Task 5-2, NIST Task R-1), and whether their scope and versions agree.
- Executive risk summary — Give the AO the system, the assessed posture, the significant risk, and the decision requested on one page: the package’s executive summary and the basis of the briefing.
- Authorization decision document — Practice recording what an AO’s decision contains: the decision, its terms and conditions, its duration, and what monitoring must report.
- Security impact analysis — Decide what a proposed or actual change does to the security posture before it goes ahead: which controls and records it touches, what must be reassessed, and who must be told (NIST M-1, JSIG 6-1).

© 2026 Secure By Design Team LLC.

RMF steps, tasks, and outputs

Each module follows one Risk Management Framework (RMF) step in NIST SP 800-37 Revision 2 order, with the matching tasks and outputs of the Joint Special Access Program Implementation Guide (JSIG), 11 April 2016.

MODULE	RMF STEP	NIST	JSIG
01 RMF roles, steps, and editions	Foundations	—	—
02 Define and register the system	Prepare	P-1–P-18	—
03 Describe and categorize the system	Categorize	C-1–C-3	1-1–1-3
04 Select controls and plan monitoring	Select	S-1–S-6	2-1–2-4
05 Implement and document the controls	Implement	I-1–I-2	3-1–3-2
06 Connect implementation to proof	Implement	I-1–I-2	3-1–3-2
07 Prepare the assessment	Assess	A-1–A-2	4-1
08 Perform and report the assessment	Assess	A-3–A-5	4-2–4-4
09 Build the plan of action and milestones	Assess	A-6	5-1
10 Assemble the authorization package	Authorize	R-1	5-2
11 Support the authorization decision	Authorize	R-2–R-5	5-3–5-4
12 Monitor and maintain authorization	Monitor	M-1–M-7	6-1–6-7

TWO DOCUMENTS, ONE SEQUENCE NIST SP 800-37 Revision 2 has seven steps, starting with Prepare. The 2016 JSIG follows Revision 1's six steps, from Categorize to Monitor, with SP 800-53 Revision 4 and CNSSI 1253 (March 2014). Confirm whether your program directs the JSIG, its successor, or other guidance.

© 2026 Secure By Design Team LLC.

RMF roles, steps, and editions

WHY THIS MATTERS Explain who performs, assesses, and approves Risk Management Framework (RMF) work, and how NIST and the Joint Special Access Program Implementation Guide (JSIG) organize its steps and outputs.

The RMF step

Who does the work NIST names roles by function (system owner, control assessor, common control provider, authorizing official); the JSIG uses SAP titles for the same work (ISO, SCA, CCP, AO) alongside the ISSM, ISSO, ISSE, and PSO. In both, only the AO accepts risk.

What this module produces

- A role map of who performs, assesses, and approves the work, in NIST and JSIG terms (the role assignments NIST covers in Task P-1)
- A record of the governing documents and editions: SP 800-37 Revision 2, the April 2016 JSIG or the successor your program directs, and the adopted SP 800-53 release
- The scope record, started with those roles and that governing direction

WHERE THE JSIG AND NIST DIFFER The JSIG of 11 April 2016 follows SP 800-37 Revision 1's six steps, starting at Categorize, with SP 800-53 Revision 4 and CNSSI 1253 (March 2014). Prepare is the NIST Revision 2 addition. DoDM 5205.07 refers to the JSIG or its successor.

Learn

01.1 Risk and the authorization decision Start with the mission, then ask about risk.

The Risk Management Framework (RMF) connects a system's purpose to the safeguards, evidence, and decisions needed to operate it. Begin with what the organization needs the system to do. Then ask what could happen if its information is exposed, changed incorrectly, or unavailable.

Each step produces outputs the next one builds on, ending in an authorization package. An Authorization to Operate (ATO) is the authorizing official's decision about the risk that remains; installing tools or finishing a checklist doesn't make it.

01.2 Roles and accountability Everyone contributes. The responsibilities differ.

NIST names roles by function: system owner, control assessor, common control provider, and authorizing official. The Joint Special Access Program (SAP) Implementation Guide (JSIG) uses SAP titles for that work: Information System Owner (ISO), Security Control Assessor (SCA), Common Control Provider (CCP), and Authorizing Official (AO).

An Information System Security Manager (ISSM) oversees the security program, an Information System Security Officer (ISSO) supports day-to-day implementation, and an Information System Security Engineer (ISSE) designs security in; SAP programs add a Program Security Officer (PSO). Local appointments set the exact split. Only the AO accepts risk.

01.3 NIST, the JSIG, and their editions Know which document, and which edition, you're following.

© 2026 Secure By Design Team LLC.

NIST Special Publication (SP) 800-37 Revision 2 (December 2018) has seven steps: Prepare, Categorize, Select, Implement, Assess, Authorize, and Monitor. Each is a set of numbered tasks, such as P-11 for the authorization boundary, with expected outputs and responsible roles. SP 800-53 supplies the controls.

The JSIG of 11 April 2016 applies that foundation to SAP systems, with SP 800-53 Revision 4 and Committee on National Security Systems Instruction (CNSSI) 1253 of March 2014. It follows SP 800-37 Revision 1's six steps, so it has no Prepare step; its tasks run from 1-1 to 6-7, and each step lists its outputs.

The public JSIG is this 2016 edition. Department of Defense Manual (DoDM) 5205.07 refers to the JSIG or its successor, so confirm what your program directs. This course follows the NIST steps, maps the JSIG tasks into each, and notes where the two differ.

Worked example: From a claim to a decision

1. **Claim —** "Privileged account changes are logged and reviewed," as the System Security Plan (SSP) states it for the practice system.
2. **Evidence —** The control owners supply the event-forwarding configuration, a sample account change from SBD-DC01, and the analyst's review record in SBD-SPLUNK01.
3. **Assessment —** The assessor (SCA) tests the event and checks that the expected review happened.
4. **Decision —** The AO weighs the supported result and any remaining gap. Only the AO can accept the risk.

Build

Start the scope record. Map who holds each role for the practice system (system owner or ISO, ISSM, ISSO, ISSE, SCA, CCP, AO, and a PSO if assigned) and mark who performs, assesses, and approves. Record the governing documents and editions, the adopted control release, and privacy responsibilities.

Practice artifacts System scope record (see Evidence starters)

Think it through

Given a missing test result and an unresolved risk, identify who supplies the evidence, who assesses it, and who can accept the risk, in NIST and JSIG terms. Then explain why the 2016 JSIG has no Prepare step.

Check your understanding

Your program directs the public JSIG of 11 April 2016. Which statement fits it?

- A. It is built on SP 800-53 Revision 5 and begins with Prepare.
- B. It replaces NIST, so SP 800-37 no longer applies.
- C. It follows SP 800-37 Revision 1's six steps, starting at Categorize, with SP 800-53 Revision 4 and CNSSI 1253.

Your record

RECORD	YOUR OBSERVATION
System scope record — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Everything you built in Build the Network is one system with one mission. Course 2.1 takes it through Prepare, Categorize, and Select, so every later record and the authorizing official’s decision rest on the same defined system.

[1] NIST SP 800-37 Revision 2

[6] DoDM 5205.07

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Define and register the system

WHY THIS MATTERS Establish what is being authorized and why: the mission, stakeholders, assets, boundary, information and its life cycle, early risks, and requirements. Then register the system.

The RMF step

Who does the work NIST gives the organization-level tasks (P-1 to P-7) to senior leaders and the risk executive function. At the system level, the mission or business owner and the system owner lead, the authorizing official determines the boundary (P-11), and the system owner registers the system (P-18). The 2016 JSIG has no Prepare step, so it assigns no roles here.

- NIST P-1 · Risk management roles
- NIST P-2 · Risk management strategy
- NIST P-3 · Risk assessment—organization
- NIST P-4 · Organizationally-tailored baselines and Cybersecurity Framework Profiles (optional)
- NIST P-5 · Common control identification
- NIST P-6 · Impact-level prioritization (optional)
- NIST P-7 · Continuous monitoring strategy—organization
- NIST P-8 · Mission or business focus
- NIST P-9 · System stakeholders
- NIST P-10 · Asset identification
- NIST P-11 · Authorization boundary
- NIST P-12 · Information types
- NIST P-13 · Information life cycle
- NIST P-14 · Risk assessment—system
- NIST P-15 · Requirements definition
- NIST P-16 · Enterprise architecture
- NIST P-17 · Requirements allocation
- NIST P-18 · System registration

The 2016 JSIG has no Prepare step.

What this module produces

- Mission and stakeholders, recorded in the scope record (P-8, P-9)
- An asset list and a documented authorization boundary, with dependencies and candidate common controls (P-10, P-11)
- Information types and their life cycle, including every boundary transfer (P-12, P-13)
- An early risk picture (P-14), carried into the draft Risk Assessment Report in module 04

© 2026 Secure By Design Team LLC.

- Requirements defined, placed in the architecture, and allocated to the system or its environment (P-15 to P-17)
- A registered system, recorded in the registration record (P-18)

> **WHERE THE JSIG AND NIST DIFFER** The 2016 JSIG has no Prepare step; it follows SP 800-37 Revision 1. It describes the system and its boundary (Task 1-2) and registers it (Task 1-3) in Categorize, and drafts its first Risk Assessment Report in Select. NIST does this work in Prepare (P-11, P-14, P-18).

Learn

02.1 Organization and mission Prepare starts above the system.

Prepare is the step NIST SP 800-37 Revision 2 added. Its organization-level tasks (P-1 to P-7) assign roles, set the risk strategy and tolerance, identify common controls systems can inherit, and set an organization-wide monitoring strategy. A system team works inside those decisions.

At the system level, start with the mission (P-8) and the stakeholders (P-9): what work the system supports, who depends on it, who owns its information, and what an interruption or misuse would affect.

02.2 Assets, boundary, and information Draw the boundary, then test the assumptions.

Identify the assets to protect (P-10), then the authorization boundary (P-11), which the authorizing official determines. It's more than a subnet diagram: consider management interfaces, hosting, shared services, information flows, and dependencies.

List the information types the system processes, stores, and transmits (P-12), and follow each from creation to disposal (P-13). A component outside the boundary can still affect risk. Record the relationship and the responsible party; don't use the boundary to make a hard dependency disappear.

02.3 Risk, requirements, and registration Assess early, allocate the requirements, then register.

Assess system risk early (P-14): threats, weaknesses, and likely consequences, so the requirements can answer them. Then define the security and privacy requirements (P-15), place the system in the enterprise architecture (P-16), and allocate each requirement to the system or its environment (P-17).

Last, the system owner registers the system with the office the organization designates (P-18). The 2016 JSIG has no Prepare step, so it describes the system and its boundary and registers it in Categorize (Tasks 1-2, 1-3), and drafts its first Risk Assessment Report (RAR) in Select.

Worked example: Resolve a boundary question

1. **Question —** Are the seven hypervisor hosts that run the enclave's servers covered by this authorization?
2. **Record —** List SBD-HV01 to SBD-HV07, who administers them, and the systems each one runs, including the domain controllers and the issuing CA.
3. **Resolve —** They can control the domain controllers, so they are Tier 0 assets wherever the line falls. Propose inside or external with the reason, and route it to the authorizing official, who determines the boundary (P-11).
4. **Prove —** Keep the asset list, boundary diagram, scope record, and registration consistent with the decision.

Build

Complete the scope record's Prepare fields for the practice system: mission and stakeholders, assets and boundary, information types and life cycle, the early risk picture, and requirements and allocation. Check each information flow against the connection map in Inside the Network, which shows every permitted, pending, and denied rule for a system. Then fill in the registration record.

Practice artifacts System scope record; System registration (see Evidence starters)

Think it through

Explain whether a hypervisor host, the core switch's management, a shared service, or an offline update transfer is inside the boundary, external, or inherited, with the supporting responsibility evidence. Say what changes in the registration if the boundary moves.

Check your understanding

Your program follows the 2016 JSIG, which has no Prepare step. Where does the boundary and registration work happen?

- A. In Categorize: describe the system and its boundary (Task 1-2), then register it (Task 1-3).
- B. Nowhere. Without a Prepare step, the JSIG skips it.
- C. In Monitor, once the system is operating.

Your record

RECORD	YOUR OBSERVATION
System scope record — location and version	
System registration — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Draw the boundary around the eight VLANs and the offline root CA, then trace each information flow across it. The hypervisor hosts, shared services and offline media transfers each need a recorded decision: inside, external, or inherited.

[1] NIST SP 800-37 Revision 2

[5] DoDI 8510.01

[6] DoDM 5205.07

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Describe and categorize the system

WHY THIS MATTERS Describe the system, justify its confidentiality, integrity, and availability impacts in the draft System Security Plan (SSP), and route the categorization for approval. Treat privacy applicability as an explicit decision.

The RMF step

Who does the work The system owner describes the system (C-1) and categorizes it with the information owner (C-2); the authorizing official or a designated representative approves the categorization (C-3). In the JSIG, the ISO categorizes with the ISSM/ISSO and ISSE (Task 1-1).

- NIST C-1 · System description
- NIST C-2 · Security categorization
- NIST C-3 · Security categorization review and approval
- JSIG Task 1-1 · Categorize the system and document the results in the SSP
- JSIG Task 1-2 · Describe the system, including its boundary, and document it in the SSP
- JSIG Task 1-3 · Register the system with the appropriate SAP Service/Agency AO or designee

What this module produces

- A documented system description in the draft SSP (C-1; JSIG Task 1-2)
- Impact levels for each information type and security objective, with a written rationale (C-2)
- The system's security categorization recorded in the draft SSP (C-2; JSIG Task 1-1)
- The categorization routed to the authorizing official or a designated representative for approval (C-3)
- The module 02 registration checked against the JSIG route (Task 1-3)

JSIG step outputs Draft SSP; System registration

WHERE THE JSIG AND NIST DIFFER NIST registers the system in Prepare (P-18) and describes it here (C-1). The JSIG describes the system and its boundary (Task 1-2) and registers it (Task 1-3) in this step.

Learn

03.1 System description Describe the system someone else will assess.

Categorize opens with a system description (C-1): what the system is for, what it contains, who uses it, what it connects to, and where its boundary lies, drawn from the Prepare records. The JSIG asks for the same in Task 1-2: describe the system, including its boundary, in the System Security Plan (SSP).

Write it so a reviewer who has never seen the system can follow it. Every later decision, from categorization to control selection, points back to this description.

03.2 Impact and rationale Evaluate the consequences for each objective.

Confidentiality concerns inappropriate disclosure, integrity improper change, and availability reliable access when needed. For each information type, judge the impact of a loss on each objective, then set the system's impact for each objective from those results (C-2), using the method that applies.

© 2026 Secure By Design Team LLC.

In the JSIG, the ISO categorizes the system with the ISSM or ISSO and the ISSE, and documents the results in the SSP (Task 1-1). Write a rationale someone else can review: the information, what's affected, the consequence, and why each level fits. An isolated network alone doesn't decide the result.

03.3 Authority, approval, and registration Apply the right authority, then get approval.

Federal systems categorize under Federal Information Processing Standard (FIPS) 199 with the information types in NIST SP 800-60; national security systems follow CNSSI 1253, and a SAP adds its program direction. Treat privacy applicability as an explicit decision.

NIST makes approval a task of its own (C-3): the authorizing official or a designated representative approves the categorization. In the JSIG, the categorization is documented in the draft SSP, and the whole plan is approved in Select (Task 2-4). This JSIG step also registers the system (Task 1-3), which NIST did in Prepare (P-18).

Worked example: A new dependency reopens availability

1. **Initial rationale —** Engineering work can wait out a short outage of the internal web application, so the exercise input rates availability Low.
2. **New information —** A deadline-driven engineering process now depends on timely access to the application on SBD-WEB01 and its records in SBD-SQL01.
3. **Review —** Reevaluate the availability consequences for those information types under the applicable method (C-2).
4. **Update —** Record the new rationale in the draft SSP and the scope record's categorization basis, route it for approval (C-3), and update the registration if the category changes.

Build

Draft the SSP's system description and security categorization from the scope record: information types, impact rationale, mission dependencies, privacy considerations, and approval routing. Justify the exercise planning input (Moderate confidentiality, Low integrity, Low availability); don't copy it. Complete the scope record's categorization basis and confirm the registration follows JSIG Task 1-3.

Practice artifacts System Security Plan; System scope record (see Evidence starters)

Think it through

Defend a changed availability impact after a new mission dependency, and explain why an air gap alone doesn't establish a low impact level. Then say who approves the categorization in NIST terms and where the JSIG documents it.

Check your understanding

The system owner has categorized the system and wants to start selecting controls. What does NIST SP 800-37 Revision 2 call for first?

- A. Nothing more. The system owner's categorization is final.

- B. Review and approval of the categorization by the authorizing official or a designated representative (C-3).
- C. A control assessment by the security control assessor.

Your record

RECORD	YOUR OBSERVATION
System Security Plan — location and version	
System scope record — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Categorization starts with the information: business files and databases on VLAN 40, the identities in the directory, and the audit record on VLAN 50. Availability follows the mission processes that depend on them.

[1] NIST SP 800-37 Revision 2

[4] NIST SP 800-53B

[5] DoDI 8510.01

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Select controls and plan monitoring

WHY THIS MATTERS Turn the approved categorization into a selected, tailored, and allocated control set, with a draft Risk Assessment Report and a continuous monitoring strategy, ready for plan review and approval.

The RMF step

Who does the work The system owner and any common control provider select, tailor, and document the controls and the monitoring strategy (S-1, S-2, S-4, S-5); security architects and the system security officer allocate them (S-3); the authorizing official or a designee approves the plan (S-6). In the JSIG, the ISO does Tasks 2-1 to 2-3 with the ISSE and/or ISSM/ISSO; the AO, SCA, or AO designee approves (2-4).

- NIST S-1 · Control selection
- NIST S-2 · Control tailoring
- NIST S-3 · Control allocation
- NIST S-4 · Documentation of planned control implementations
- NIST S-5 · Continuous monitoring strategy—system
- NIST S-6 · Plan review and approval
- JSIG Task 2-1 · Identify common controls and document them in a security plan
- JSIG Task 2-2 · Select the security controls for the information system and document the controls in the security plan
- JSIG Task 2-3 · Develop a strategy for continuous monitoring of security control effectiveness
- JSIG Task 2-4 · Review and approve the SSP

What this module produces

- Selected and tailored controls, with parameters and rationale, in the SCTM (S-1, S-2)
- Controls allocated to the system, its components, or a common control provider (S-3; JSIG Task 2-1)
- Planned implementations documented in the security plan and SCTM (S-4; JSIG Task 2-2)
- A draft Risk Assessment Report built from the early risk picture and the planned controls (JSIG Step 2 output)
- A system continuous monitoring strategy, including reporting and decommissioning (S-5; JSIG Task 2-3)
- The plan routed for review and approval (S-6; JSIG Task 2-4)

JSIG step outputs Updated draft SSP/SCTM; Draft Risk Assessment Report (RAR); Documented Continuous Monitoring (ConMon) Plan/Strategy; Approved draft SSP/SCTM

WHERE THE JSIG AND NIST DIFFER The JSIG produces a draft RAR in this step and updates it in Assess; NIST assesses system risk in Prepare (P-14) and analyzes and determines it in Authorize (R-2).

Learn

04.1 Baselines, overlays, and tailoring A catalog is not the same as a selected control set.

© 2026 Secure By Design Team LLC.

SP 800-53 is a catalog; a baseline is a starting set under a selection method, and overlays can change it. SP 800-53B holds the federal baselines; a national security system selects under CNSSI 1253 and its overlays, and a SAP adds the JSIG and approved program direction.

Select the controls (S-1), then tailor them (S-2): record why each is added, adjusted, or not applicable, resolve organization-defined parameters such as roles and frequencies, and note who approves. Difficulty alone doesn't make a requirement not applicable.

04.2 Allocation and the security plan Allocate the work before asking for evidence.

Allocate each control to the system, its components, or its environment (S-3), and name its owner: system-specific, common from a provider, or hybrid with shared responsibility. The JSIG begins Select here, with Task 2-1: identify the common controls and document them in a security plan.

Then document the planned implementations (S-4). The JSIG's Task 2-2 selects the controls and documents them in the security plan. A Security Controls Traceability Matrix (SCTM) can record each control's selection, parameters, allocation, and inheritance; its format follows local requirements.

04.3 Risk, monitoring, and plan approval Plan how you'll know it still works, then get approval.

A system continuous monitoring strategy (S-5; JSIG Task 2-3) says which controls are monitored, how often, by whom, and what triggers action, within the organization's strategy (P-7). The JSIG also drafts a Risk Assessment Report (RAR) here; NIST assessed system risk in Prepare (P-14).

Then the plan is reviewed and approved: by the authorizing official or a designated representative in NIST (S-6), or by the AO, SCA, or AO designee in the JSIG (Task 2-4). The JSIG calls the result the approved draft SSP/SCTM.

Worked example: Credentialed scanning isn't built yet

1. **Proposal —** "Mark RA-5 not applicable until a credentialed scanner exists."
2. **Question —** Is the control inapplicable, or only hard to meet today? The network still runs software that needs vulnerability monitoring.
3. **Decision —** Keep RA-5 selected. Allocate what exists, SCAP Compliance Checker and Security Technical Implementation Guide (STIG) results from the administration seats, and record credentialed scanning as a gap.
4. **Record —** The SCTM row shows the allocation and the gap, the draft RAR carries the risk, and the monitoring strategy reviews scan coverage.

Build

Start the Security Controls Traceability Matrix (SCTM) with each selected control's adopted revision, source, tailoring rationale, parameters, owner, and system-specific, common, or hybrid allocation. Draft the Risk Assessment Report (RAR) from the module 02 risk picture, write the continuous monitoring strategy, and route the plan for approval.

Practice artifacts Security Controls Traceability Matrix; Risk Assessment Report; Continuous monitoring strategy (see Evidence starters)

Think it through

Resolve a proposed not-applicable control and an inherited-control claim using evidence and the required approval path. Show which monitoring activity watches each draft RAR risk, and pin the control and assessment-procedure versions.

Check your understanding

A facility office says physical access to the server room is “covered.” What does the SCTM need before the plan goes for approval?

- A. Nothing more. Mark PE-3 inherited on the provider’s word.
- B. Mark PE-3 not applicable, since the system team doesn’t run the building.
- C. The provider, the parts it performs, its assessment information, and what the system team still does.

Your record

RECORD	YOUR OBSERVATION
Security Controls Traceability Matrix — location and version	
Risk Assessment Report — location and version	
Continuous monitoring strategy — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Each practice control lands on real systems: account management (AC-2) on the domain controllers, audit (AU-2, AU-6, AU-12) on the collector and VLAN 50, and flaw remediation (SI-2) through SBD-WSUS01 and SBD-REPO01. The traceability matrix records who implements each one.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[3] NIST SP 800-53A Revision 5

[4] NIST SP 800-53B

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Implement and document the controls

> **WHY THIS MATTERS** Implement the selected controls and record them as built in the System Security Plan (SSP) and Security Controls Traceability Matrix (SCTM), in statements an assessor can test.

The RMF step

Who does the work NIST gives I-1 and I-2 to the system owner and any common control provider, with engineers and security staff supporting. The Joint Special Access Program (SAP) Implementation Guide (JSIG) gives Tasks 3-1 and 3-2 to the Information System Owner (ISO), working with the Information System Security Engineer (ISSE).

- NIST I-1 · Control implementation
- NIST I-2 · Update control implementation information
- JSIG Task 3-1 · Implement the security controls specified in the SSP
- JSIG Task 3-2 · Document the control implementation in the SCTM portion of the SSP

What this module produces

- The controls the Build the Network courses put in place, checked against the approved selection and parameter values (NIST I-1; JSIG 3-1)
- As-implemented SSP statements for each practice control: who, what, where, when, and which records (I-2)
- SCTM rows updated with implementation status and evidence references (JSIG 3-2, output “Updated SSP/SCTM”)
- Planned work and differences from the approved plan recorded, not presented as operating
- Supporting plans referenced by owner, version, and review status

JSIG step outputs Updated SSP/SCTM

> **WHERE THE JSIG AND NIST DIFFER** The JSIG records the implementation in the SCTM portion of the SSP. NIST updates the security and privacy plans themselves, with as-implemented detail sufficient for an assessor to use.

Learn

05.1 Implement the approved controls Build what the approved plan describes.

Implement turns the approved plan into a working system. NIST Task I-1 implements the controls in the security and privacy plans; Task 3-1 of the Joint Special Access Program (SAP) Implementation Guide (JSIG) implements those specified in the System Security Plan (SSP).

The system owner is accountable, and engineers build to the approved selection, parameter values, and control revision. That revision matters: the public JSIG is the 11 April 2016 edition, built on SP 800-53 Revision 4 and CNSSI 1253, and a program may direct a successor or its own guidance.

05.2 As-implemented statements Record the controls as they were built.

© 2026 Secure By Design Team LLC.

NIST Task I-2 updates the plans with the as-implemented state, in enough detail for an assessor to use. JSIG Task 3-2 records it in the Security Controls Traceability Matrix (SCTM) portion of the SSP. Both lead to the JSIG output “Updated SSP/SCTM.”

Write who performs each activity, what happens, where it applies, when it happens, and which records show it. “We comply with policy” leaves an assessor nothing to examine, interview, or test.

05.3 Planned work and supporting plans Keep planned work and supporting plans honest.

Describe what operates today, and mark planned work as planned. Where the build could not follow the plan, say so; the assessor will test each statement as written.

Configuration, access, incident response, contingency, and other supporting plans describe processes the SSP relies on. Reference each by owner, version, and review status instead of copying procedures that drift apart. A plan shows intent; records show the process happens.

Worked example: Turn a vague statement into an as-implemented one

1. **Before —** “Audit records are reviewed according to policy.” It names no reviewer, sources, schedule, or record.
2. **As built —** Windows systems forward the selected events to SBD-SYSLOG01 by Windows Event Forwarding (F17), the Linux servers send syslog over TLS (F07), and the collector feeds SBD-SPLUNK01 (F10) and SBD-AUDIT01 (F11).
3. **After —** The assigned analyst reviews those events in SBD-SPLUNK01 on the approved schedule, records each exception and its follow-up, and keeps the review record.
4. **Trace —** Put the statement in the SSP and update the AU-6 row of the SCTM with its status and evidence identifiers, ready for the assessor.

Build

Update the SSP that course 2.1 drafted with as-implemented statements for the practice controls (AU-2, AU-3, AU-6, AU-12): who performs each activity, what happens, where, when, and which records show it. Update the matching SCTM rows with implementation status and evidence references, and mark planned work as planned.

Practice artifacts System Security Plan; Security Controls Traceability Matrix (see Evidence starters)

Think it through

Replace a vague “compliant with policy” statement with a specific as-implemented narrative. Reconcile it with the diagrams, inventory, and inheritance record, and show how you would record a difference between the build and the approved plan.

Check your understanding

The engineers built the log path differently from the approved plan. What does the Implement step call for?

- A. Leave the plan as approved and let the assessor find the difference.

- B. Update the SSP and SCTM to the as-implemented state.
- C. Change the system back, whatever the reason for the difference.

Your record

RECORD	YOUR OBSERVATION
System Security Plan — location and version	
Security Controls Traceability Matrix — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The system security plan describes this network as it is: each VLAN and its systems, the administration tiers, and the permitted paths between them. Every implementation statement names who does what, where, and when.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[6] DoDM 5205.07

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Connect implementation to proof

> **WHY THIS MATTERS** Collect technical and operational evidence of the as-built system, index it, and correct the SSP and SCTM wherever the evidence and the plan disagree.

The RMF step

Who does the work Engineers and administrators produce the records, and common control providers supply evidence for what the system inherits. The system owner (in the JSIG, the ISO with the ISSE) keeps the SSP and SCTM true to that evidence.

- NIST I-1 · Control implementation
- NIST I-2 · Update control implementation information
- JSIG Task 3-1 · Implement the security controls specified in the SSP
- JSIG Task 3-2 · Document the control implementation in the SCTM portion of the SSP

What this module produces

- Configuration evidence with system, scope, version, and collection time: scan results, hardening checklists, exports (I-1)
- Operational records that show processes run, such as log reviews and a restore test
- A master evidence index giving each record an identifier, owner, date, scope, and version
- Coverage gaps and limitations recorded, including credentialed vulnerability scanning not yet available
- SSP and SCTM corrected to the as-built state (I-2; JSIG output “Updated SSP/SCTM”)

JSIG step outputs Updated SSP/SCTM

> **WHERE THE JSIG AND NIST DIFFER** The JSIG calls the record an assessment rests on the Body of Evidence (BoE): the SSP, test plans, test procedures, test reports, and exceptions. NIST SP 800-37 treats the same material task by task: updated plans (I-2), assessment plans (A-2), assessment evidence (A-3), and assessment reports (A-4).

Learn

06.1 Configuration and hardening evidence Capture the configuration and its context.

Evidence shows what Implement actually produced. A configuration export or Security Technical Implementation Guide (STIG) checklist is useful when a reviewer can identify the system, setting, scope, version, and collection time. Keep the review record alongside it.

A passing automated check has a defined scope. Manual checks, applicability decisions, and technical limits still need attention.

06.2 Security operations evidence Show that processes run, and how far the evidence reaches.

Logs, review records, tickets, access reviews, and restore tests support different claims. Connect each item to the question it can answer. Owning a security product does not show that a control is effective; its records might.

© 2026 Secure By Design Team LLC.

Check that every relevant system was included, the collection worked, and the data is current. Keep collection failures rather than silently excluding them, and say what an item cannot show: a backup job's success message does not prove recovery.

06.3 The evidence index and the as-built plan Index the evidence, then let it correct the plan.

A master evidence index gives each record a stable identifier, title, scope, owner, collection date, version, and location, so nobody depends on a folder name or someone's memory. One record can support several objectives, and one objective can need several records.

When the evidence shows the system differs from the SSP or SCTM, update them to the as-built state. That is still NIST Task I-2 and JSIG Task 3-2, and it means the assessor tests the real system.

Worked example: A clean view with a coverage gap

1. **Result —** A Splunk search by host shows recent events from the domain controllers and member servers.
2. **Inspection —** The audit source inventory lists SBD-MGMT01, but none of its events reached SBD-SYSLOG01 in the collection period.
3. **Conclusion —** The evidence does not support complete source coverage, so the SSP's AU-12 statement cannot claim it.
4. **Follow-up —** Record the gap in the evidence index and the SSP, and hand it to the assessor. Do not drop SBD-MGMT01 from the inventory to make the view look complete.

Build

Collect configuration exports, reviewed STIG checklists, SCAP Compliance Checker results with their coverage, log review records, and the course 1.19 restore record, or equivalent supplied training records. Start the master evidence index, and correct the SSP and SCTM wherever the evidence shows the system differs from the plan.

Practice artifacts Master evidence index (see Evidence starters)

Think it through

Explain what each item proves and leaves untested. Identify a scan that missed an in-scope host, an unreviewed alert, and a configuration screenshot that lacks system or time context. Record credentialed vulnerability scanning (RA-5) as a limitation: the practice network does not run it yet.

Check your understanding

A configuration scan reports no open findings, but one in-scope server is missing from its results. What does the scan support?

- A. A clean result for every in-scope server.
- B. Nothing, so it should be deleted.
- C. A clean result for the servers it covered; the missing server is a coverage gap to record and close.

Your record

RECORD	YOUR OBSERVATION
Master evidence index — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Proof comes from the systems themselves: SCAP Compliance Checker results and STIG checklists from the administration seats, log review records from SBD-SPLUNK01, and the course 1.19 restore record.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[3] NIST SP 800-53A Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Prepare the assessment

> **WHY THIS MATTERS** Select an independent assessor, hand over current evidence, and get a Security Assessment Plan approved before any testing starts.

The RMF step

Who does the work The Authorizing Official (AO) or a designated representative selects the assessor (A-1) and, in NIST, approves the plan the assessor develops (A-2). In the JSIG, the ISO develops the plan with the Information System Security Manager (ISSM), Information System Security Officer (ISSO), or ISSE, and the Security Control Assessor (SCA) reviews and approves it (4-1).

- NIST A-1 · Assessor selection
- NIST A-2 · Assessment plan
- JSIG Task 4-1 · Develop, review, and approve a plan to assess the security controls

What this module produces

- An assessor or team selected by the AO or designated representative, with the independence required (NIST A-1)
- A record of the evidence handed over: SSP, SCTM, evidence index, and known exceptions, with versions
- A Security Assessment Plan with scope, objectives, methods, objects, procedures, sampling, schedule, and limits (A-2; JSIG 4-1)
- The plan’s review and approval, recorded before testing (JSIG output “Security Assessment Plan”)

JSIG step outputs Security Assessment Plan

> **WHERE THE JSIG AND NIST DIFFER** Assessor selection is a separate task only in NIST (A-1). NIST has the assessor develop the plan for the AO’s approval; the JSIG has the ISO’s team develop it and the SCA approve it, and defines it as the SSP, the SCTM, and the Security Control Assessment Procedures.

Learn

07.1 Assessor selection and independence Choose an assessor who can be trusted with the answer.

NIST Task A-1 opens Assess: the Authorizing Official (AO), or a designated representative, selects the assessor or team. In the JSIG, Step 4 starts with the plan, and the Security Control Assessor (SCA) is a defined role.

Choose for skill and independence. An impartial assessor does not assess their own work or advocate for the team that built it. The AO decides how much independence the system’s categorization and risk call for.

07.2 The evidence the assessor receives Hand over evidence the assessor can rely on.

The assessor starts from what Implement produced: the SSP, the SCTM, the evidence index, and the exceptions you already know about. Check that each record is current, and record the versions you hand over so the plan and results refer to the same material.

© 2026 Secure By Design Team LLC.

The JSIG describes this as the Body of Evidence (BoE): the SSP, test plans, test procedures, test reports, and exceptions. The system team supplies the plan and the exceptions; the assessment adds the rest.

07.3 The Security Assessment Plan Agree on the plan before anyone tests.

In NIST Task A-2, the assessor develops the plan from the implementation detail, and the AO or a designated representative approves it. In JSIG Task 4-1, the ISO develops it with the information system security manager, officer, or engineer, and the SCA reviews and approves it.

The JSIG's Security Assessment Plan is made up of the SSP, the SCTM, and the Security Control Assessment Procedures. Either way, the plan states scope, objectives, methods, objects, coverage, responsibilities, schedule, and limits, with sampling decisions written down.

Worked example: Plan the logging assessment

1. **Assessor —** The exercise AO's designated representative selects a training assessor who did not build or operate the logging pipeline.
2. **Evidence —** The assessor receives the SSP and SCTM at their recorded versions, evidence index EI-001, and the known SBD-MGMT01 coverage gap.
3. **Procedures —** Examine the event configuration and source records, interview the analyst, test an approved account change on SBD-DC01, and replay the attack drill's six attempts as negative tests.
4. **Approval —** Plan AP-001 is reviewed and approved before any testing: by the SCA in JSIG terms, or by the AO or a designated representative in NIST's.

Build

Record who selected the assessor and the independence they provide. List the evidence handed over, with versions and known exceptions. Draft a Security Assessment Plan for the practice logging objectives: scope, objectives, methods, objects, sampling rationale, the attack drill's six attempts as negative tests, responsibilities, schedule, and limits. Record its review and approval.

Practice artifacts Security Assessment Plan; Master evidence index (see Evidence starters)

Think it through

Check the handover before approval: find stale evidence, a missing record, and a mismatch between the SSP and an exported configuration, and record each gap's effect on the plan. Explain why your assessor is independent enough for this system.

Check your understanding

The engineer who built the logging pipeline offers to assess it. What is the problem?

- A. An assessor should not assess their own work; the AO sets the independence required.
- B. None, as long as the engineer follows the procedures.
- C. Engineers cannot take part in an assessment at all.

Your record

RECORD	YOUR OBSERVATION
Security Assessment Plan — location and version	
Master evidence index — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The assessor works from records you already keep: the evidence folders on the administration seats, the protected archive on SBD-AUDIT01, and the living inventory on SBD-MGMT01. The assessment plan names which records and systems each procedure covers.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[3] NIST SP 800-53A Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Perform and report the assessment

> **WHY THIS MATTERS** Assess the controls as planned, report supported findings in a Security Assessment Report (SAR), and remediate and reassess what can be fixed now.

The RMF step

Who does the work The control assessor performs the assessment and writes the report; in the JSIG that is the SCA or an AO designee, and the SCA submits the SAR with a recommended authorization decision. The system owner carries out initial remediation, and the assessor reassesses (A-5).

- NIST A-3 · Control assessments
- NIST A-4 · Assessment reports
- NIST A-5 · Remediation actions
- JSIG Task 4-2 · Assess the security controls per the Security Assessment Plan
- JSIG Task 4-3 · Prepare the Security Assessment Report (SAR)
- JSIG Task 4-4 · Conduct initial remediation based on the SAR and reassess remediated controls

What this module produces

- Completed assessments with the observation and evidence for each objective (A-3; JSIG 4-2)
- A SAR with results, findings, limitations, and recommendations (A-4; JSIG output “SAR”)
- Initial remediation and reassessment, with original findings kept in the updated SAR (A-5; JSIG 4-4)
- The SSP updated where an implementation changed (A-5; JSIG output “Updated SSP”)
- The Risk Assessment Report (RAR) updated with the risk from confirmed weaknesses (JSIG output “Updated RAR”)

JSIG step outputs SAR; Updated RAR; Updated SSP

> **WHERE THE JSIG AND NIST DIFFER** The JSIG updates the RAR here and has the SCA submit the SAR with a recommended authorization decision. NIST assesses system risk in Prepare (P-14) and analyzes and determines it in Authorize (R-2); its assessment report carries findings and recommendations for correcting deficiencies.

Learn

08.1 Examine, interview, and test Run the approved procedures and record what you see.

NIST Task A-3 and JSIG Task 4-2 assess the controls the way the approved plan describes. Each assessment asks whether a control is implemented correctly, operating as intended, and producing the desired outcome.

Examine records and configurations, interview the people who run the process, and test behavior where the plan calls for it, including what should fail. Record the expected result, the observation, the evidence, and any limitation, using the adopted SP 800-53A procedures.

08.2 The Security Assessment Report Report only what the evidence supports.

© 2026 Secure By Design Team LLC.

NIST Task A-4 and JSIG Task 4-3 produce the Security Assessment Report (SAR): what was assessed, the result for each objective, the findings and limitations, and recommendations for correcting deficiencies. An objective the evidence cannot support is “other than satisfied,” not a pass by default.

In the JSIG, the SCA submits the SAR with a recommended authorization decision. The recommendation informs the AO; it is not the decision.

08.3 Initial remediation and reassessment Fix what you can, reassess it, and keep the record.

NIST Task A-5 and JSIG Task 4-4 cover initial remediation. Review each finding’s significance; the system owner corrects those that should be fixed now, and the assessor reassesses the changed controls. The SAR keeps the original finding beside the new result.

Then update what the results changed: the SSP for any implementation that moved and, in the JSIG, the Risk Assessment Report (RAR) drafted in Select. Whatever stays open goes to the Plan of Action and Milestones (POA&M).

Worked example: Assess the logging objectives

1. **Test —** Make an approved account change on SBD-DC01 and follow it through SBD-SYSLOG01 to SBD-SPLUNK01 and the analyst’s review. Replay the attack drill: all six attempts should be refused.
2. **Observe —** The event arrives and is reviewed (EV-003, EV-004), and every drill attempt is refused. SBD-MGMT01 has no verified events in the period, and one review exception has no recorded follow-up.
3. **Report —** SAR-001 records the results, FND-001 for SBD-MGMT01 coverage, and FND-002 for the missing follow-up, and cites the traffic matrix for the drill.
4. **Remediate —** The analyst records the follow-up, and the reassessment finds the AU-6 objective satisfied; FND-002 stays in the report as remediated. FND-001 needs a scheduled change, so it stays open for the POA&M.

Build

Run the procedures in your approved plan and prepare a SAR excerpt. Include negative tests: run the six attempts in the Inside the Network attack drill, record each expected and observed result in the Operational verification column of the network traffic matrix, and cite the matrix in your SAR. Remediate one finding, reassess it, and update the SSP and the Risk Assessment Report (RAR) that course 2.1 drafted.

Practice artifacts Security Assessment Report; Risk Assessment Report (see Evidence starters)

Think it through

Link each conclusion to its objective, evidence, observation, and limitation. Record unsupported objectives as other than satisfied rather than treating missing evidence as a pass, and show a remediated finding still in the report beside its reassessment.

Check your understanding

During the assessment, the team fixes a finding and the reassessment passes. What happens to the original finding in the SAR?

- A. It is deleted, since the control now works.
- B. It stays, with the remediation and the reassessment result beside it.
- C. It moves to the POA&M as an open item.

Your record

RECORD	YOUR OBSERVATION
Security Assessment Report — location and version	
Risk Assessment Report — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Assessment tests what should fail as well as what should work. The attack drill's six attempts should all be refused; the three that cross VLANs are drawn here: a PC to SQL, a PC to Splunk, and a stolen session on SBD-ADMIN-PC01 aimed at a domain controller.

[1] NIST SP 800-37 Revision 2

[3] NIST SP 800-53A Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Build the plan of action and milestones

WHY THIS MATTERS Turn the findings still open into a risk-ranked Plan of Action and Milestones (POA&M) with accountable owners, resources, dated milestones, and closure criteria.

The RMF step

Who does the work NIST gives A-6 to the system owner and any common control provider. In the JSIG, the ISO initiates and updates the POA&M (5-1), and the AO uses it to monitor progress.

- NIST A-6 · Plan of action and milestones
- JSIG Task 5-1 · Initiate and update the POA&M from the SAR's findings and recommendations

What this module produces

- A POA&M entry for each finding still open after initial remediation (A-6; JSIG output "POA&M")
- Entries ranked by contextual risk, not technical severity alone
- An accountable owner, resources, milestones, and completion dates for each entry
- Closure criteria tied to reassessment, linked to the SAR finding and the RAR

JSIG step outputs POA&M

WHERE THE JSIG AND NIST DIFFER NIST prepares the POA&M at the end of Assess (A-6); the JSIG initiates it as the first task of Authorize (5-1). Both build it from the assessment report's findings and recommendations.

Learn

09.1 From findings to ranked risk Rank what is still open by risk.

Findings that survive initial remediation go into the Plan of Action and Milestones (POA&M). NIST Task A-6 prepares it from the assessment report's findings and recommendations; JSIG Task 5-1 initiates it the same way, as the first task of Authorize.

Rank the entries by risk in the system's context: threat, exposure, mission consequence, existing safeguards, and remaining uncertainty. Technical severity informs the order, but it is not the complete risk determination.

09.2 Writing an actionable POA&M Write an action someone can manage.

Each entry names the weakness, affected scope, accountable owner, planned actions, resources, milestones with completion dates, dependencies, and closure criteria. In the JSIG, the ISO keeps it updated with corrective actions, resources, milestone completion dates, and residual findings.

"Fix soon" is not a milestone. A useful milestone describes a verifiable action with a target date and a clearly accountable owner.

09.3 Tracking to verified closure Track each entry to verified closure.

The AO reviews the POA&M and uses it to monitor progress. Close an entry only when a reassessment verifies the fix, and keep the original finding and dates when plans change.

© 2026 Secure By Design Team LLC.

A POA&M is a management record; it does not accept risk or grant permission to operate. Tracking a weakness and accepting its risk are different actions, and only the AO accepts risk.

Worked example: Turn the open logging finding into a POA&M entry

1. **Finding —** FND-001: SBD-MGMT01 is not in verified audit collection. It remained open after initial remediation because the fix needs a scheduled change.
2. **Risk —** Privileged activity on a management server could go unreviewed. Weigh the local records that remain, then set the entry's contextual risk and rank.
3. **Milestones —** Confirm the forwarding configuration, test a selected event end to end, and verify the analyst's review covers SBD-MGMT01, each with an owner and a date.
4. **Closure —** Close PM-001 only after reassessment, then update the SSP, evidence index, RAR, and SAR. FND-002 was fixed during the assessment and needs no entry.

Build

Rank the findings still open after initial remediation and write a POA&M entry for each: the weakness, affected assets and controls, owner, resources, milestones with target dates, status, and closure criteria tied to reassessment. Link each entry to its SAR finding and the RAR.

Practice artifacts Plan of Action and Milestones (see Evidence starters)

Think it through

Prioritize two findings with different exposure and mission impact, and defend the order. Explain why a finding fixed and reassessed during the assessment needs no entry, and why an open entry cannot close without a verified reassessment.

Check your understanding

Does adding a finding to the POA&M mean its risk has been accepted?

- A. Yes, automatically.
- B. Only if the entry has a due date.
- C. No. Only the AO accepts risk, as part of the authorization decision.

Your record

RECORD	YOUR OBSERVATION
Plan of Action and Milestones — location and version	
Reviews or approvals recorded	

RECORD	YOUR OBSERVATION
Open questions carried forward	

> **IN YOUR NETWORK** The worked finding is in this network: SBD-MGMT01 missing from verified audit collection. The POA&M entry restores collection, retests the selected event, and keeps the original result until the retest verifies the fix.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Assemble the authorization package

WHY THIS MATTERS Assemble an authorization package whose plans, assessment results, and open risks agree, and submit it for the authorizing official's decision.

The RMF step

Who does the work The system owner (in the JSIG, the Information System Owner, ISO) assembles and submits the package; a common control provider does the same for the controls it provides. The Authorizing Official (AO) receives it and may direct additional evidence.

- NIST R-1 · Authorization package
- JSIG Task 5-2 · Assemble and submit the security authorization package to the AO

What this module produces

- An authorization package assembled and submitted to the AO (NIST R-1; JSIG output: Security Authorization Package)
- An executive summary of the system, the assessment results, and the remaining risk (NIST R-1)
- A versioned package manifest naming each component, its basis, owner, and review check
- A consistency review that reconciles scope, inventory, findings, and open actions across the SSP, SCTM, RAR, SAR, and POA&M

JSIG step outputs Security Authorization Package

WHERE THE JSIG AND NIST DIFFER The JSIG's minimum package is the SSP (with the SCTM, continuous monitoring strategy, and RAR), the SAR, and the POA&M, plus any evidence the AO directs. NIST R-1 adds an executive summary and treats privacy plans and privacy assessment reports alongside the security ones.

Learn

10.1 Package contents in the JSIG and NIST Assemble what the decision needs.

In NIST SP 800-37 Revision 2, Task R-1, the system owner assembles the authorization package and submits it to the Authorizing Official (AO). It holds an executive summary, the security and privacy plans, the assessment reports, and the Plan of Action and Milestones (POA&M).

The Joint Special Access Program (SAP) Implementation Guide (JSIG) applies that NIST foundation to SAP systems; its public edition, 11 April 2016, is built on SP 800-53 Revision 4. Its Task 5-2 sets a minimum: the System Security Plan (SSP), with its Security Controls Traceability Matrix (SCTM), continuous monitoring strategy, and Risk Assessment Report (RAR); the Security Assessment Report (SAR); and the POA&M. The AO can direct more.

10.2 Consistency and readiness review Check that the documents agree.

Compare the boundary, inventory, selected controls, implementation statements, findings, and open actions across the SSP, SCTM, RAR, SAR, and POA&M. Resolve identifiers, status, dates, and scope that disagree.

© 2026 Secure By Design Team LLC.

Follow the risk as well: each significant SAR finding should reach the RAR, the POA&M or a proposed acceptance, and the executive summary. A package can be complete as a collection of files and still be unreliable.

10.3 Submission workflow Submit through the approved workflow.

Follow the authority's system of record, required reviews, signatures, and submission steps. In the Enterprise Mission Assurance Support Service (eMASS) or another tool, the records still need the same substance.

Submitting hands the package to the AO; it decides nothing. This course uses a generic record workflow, and no live government submission is part of the training.

Worked example: A package consistency review

1. **SSP —** Describes 21 named systems, two of them planned and not yet built (SBD-NESSUS01, SBD-EPO01), and 50 Windows workstations.
2. **SAR —** Reports testing on the network for 18 named systems and the workstation sample.
3. **Reconcile —** Nothing claims the planned servers' controls. SBD-ROOTCA01 is never on the network, so it is assessed during its key ceremonies: a stated limitation, not a missing test.
4. **Record —** Note each explanation in the manifest's review checks and the executive summary before submitting.

Build

Assemble the practice system's package: an executive summary, the SSP with its SCTM, continuous monitoring strategy, and RAR, the SAR, the POA&M, and a privacy applicability record. List each in a versioned manifest with its basis (JSIG 5-2 or NIST R-1), owner, and review check.

Practice artifacts Authorization package manifest; Executive risk summary (see Evidence starters)

Think it through

Reconcile control identifiers, asset counts, findings, dates, and status across the SSP, SCTM, RAR, SAR, and POA&M, and explain each difference you keep. Walk the package through a generic eMASS-style submission using training data.

Check your understanding

Your authority follows the JSIG. What must the authorization package contain at a minimum?

- A. The executive summary only; the AO requests the rest.
- B. The SSP and the latest scan report.
- C. The SSP (with its SCTM, continuous monitoring strategy, and RAR), the SAR, and the POA&M, plus any evidence the AO directs.

Your record

RECORD	YOUR OBSERVATION
Authorization package manifest — location and version	
Executive risk summary — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The package has to agree with itself: 21 named systems and 50 workstations in the SSP, and an assessment that explains why the offline root CA is tested only during its key ceremonies.

[1] NIST SP 800-37 Revision 2

[5] DoDI 8510.01

[6] DoDM 5205.07

[7] DCSA Voice of Industry · September 2025

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Support the authorization decision

WHY THIS MATTERS Brief the risk the authorizing official must determine, propose a response to each significant risk, and record what an authorization decision contains.

The RMF step

Who does the work The AO, helped by a designated representative for everything but the decision itself, determines the risk and chooses the response; making and signing the decision stays with the AO. The system owner (JSIG: ISO) and the Security Control Assessor (SCA) brief the risk and answer questions.

- NIST R-2 · Risk analysis and determination
- NIST R-3 · Risk response
- NIST R-4 · Authorization decision
- NIST R-5 · Authorization reporting
- JSIG Task 5-3 · Determine the risk
- JSIG Task 5-4 · Determine whether the risk is acceptable (the authorization decision)

What this module produces

- A risk determination for operating the system, informed by the package and risk assessments (NIST R-2; JSIG 5-3)
- A response to each significant risk: mitigation tracked in the POA&M or set as conditions, acceptance, or avoidance (NIST R-3)
- An authorization decision document: ATO, IATT, or DATO, with terms and conditions and a duration (NIST R-4; JSIG 5-4)
- A report of the decision and any significant control deficiencies to the officials who oversee risk (NIST R-5)
- An executive risk summary and AO briefing that support the decision without making it

JSIG step outputs Authorization decision document

WHERE THE JSIG AND NIST DIFFER The JSIG's decisions are ATO, IATT, and DATO; NIST names authorization to operate, authorization to use, common control authorization, or a denial. NIST also makes risk response (R-3) and authorization reporting (R-5) tasks of their own; the JSIG covers the AO's work in Tasks 5-3 and 5-4.

Learn

11.1 Risk determination Support the AO's risk determination.

In NIST Task R-2, the AO analyzes the package and determines the risk of operating the system. In JSIG Task 5-3, risk assessments, formal or informal, inform the AO's final determination.

Your briefing supports that analysis: the mission, the assessed posture, significant findings and their consequences, limitations, and the recommendation the Security Control Assessor (SCA) made with the SAR. A request for more evidence is part of the process, not a setback.

© 2026 Secure By Design Team LLC.

11.2 Risk response Choose a response for each significant risk.

In NIST Task R-3, the AO chooses a response to the risk determined. Planned mitigation is tracked in the POA&M, and conditions on operation go into the decision. Accepted deficiencies stay documented in the assessment report and are watched for change. Avoiding a risk can mean limiting the operation.

A POA&M entry tracks work; it doesn't accept risk. JSIG Task 5-4 puts the explicit acceptance of risk with the AO, who decides whether the risk to organizational operations and assets, individuals, other organizations, or national security is acceptable.

11.3 The decision and its reporting Record the decision so people can act on it.

The authorization decision document records the decision, its terms and conditions, and its duration. JSIG decisions are an Authorization to Operate (ATO), an Interim Authorization to Test (IATT), for testing rather than operation, or a Denied Authorization to Operate (DATO). NIST Task R-4 names authorization to operate or to use, common control authorization, or a denial.

Duration is time-driven or ongoing, backed by robust continuous monitoring. Only the AO makes and signs the decision. NIST Task R-5 then reports it, with any significant control deficiencies, to the officials who oversee risk.

Worked example: From an open finding to a decision record

1. **Determine —** FND-001: SBD-MGMT01 is missing from verified audit collection, so privileged activity there could go unseen in Splunk review.
2. **Respond —** Mitigate through PM-001, and propose an interim condition: the Information System Security Officer (ISSO) reviews SBD-MGMT01's local Security log and records each review.
3. **Decide —** The reviewer, acting as AO, records an exercise decision: the type, terms and conditions tied to PM-001, and a duration.
4. **Report —** Monitoring reports PM-001's milestones and the interim reviews. A course score is not an ATO.

Build

Write the executive risk summary and a five-minute AO briefing for the practice system. Then complete a fictional decision record: the decision type, terms and conditions, duration, and what monitoring must report.

Practice artifacts Executive risk summary; Authorization decision document (see Evidence starters)

Think it through

Defend one unresolved finding and answer a request for more evidence. Propose a response (mitigate, accept, or avoid), and explain why the decision belongs to the AO and why a complete package or a passing score doesn't produce an ATO.

Check your understanding

The AO will allow operation while an open finding is fixed. What must the decision document record?

- A. The decision, the terms and conditions tied to that finding, and the duration.
- B. Only the POA&M due dates.
- C. Nothing more: the open POA&M entry already accepts the risk.

Your record

RECORD	YOUR OBSERVATION
Executive risk summary — location and version	
Authorization decision document — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The Authorizing Official decides for the whole system, not one server at a time. The briefing explains what this network enables, the risk that remains, and the conditions and monitoring that would come with an authorization.

[1] NIST SP 800-37 Revision 2

[5] DoDI 8510.01

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Monitor and maintain authorization

WHY THIS MATTERS Keep the authorization true as the system changes: analyze each change, assess and report as the strategy requires, support ongoing authorization, and plan disposal.

The RMF step

Who does the work The system owner (JSIG: ISO), with the Information System Security Manager (ISSM) and the ISSO, analyzes changes, remediates, updates the package, reports status, and carries out disposal. The control assessor (JSIG: SCA) runs the ongoing assessments. The AO, or in the JSIG a designee, reviews the status and decides whether the risk is still acceptable.

- NIST M-1 · System and environment changes
- NIST M-2 · Ongoing assessments
- NIST M-3 · Ongoing risk response
- NIST M-4 · Authorization package updates
- NIST M-5 · Security and privacy reporting
- NIST M-6 · Ongoing authorization
- NIST M-7 · System disposal
- JSIG Task 6-1 · Determine the security impact of proposed or actual changes
- JSIG Task 6-2 · Assess a selected subset of controls under the AO-approved monitoring strategy
- JSIG Task 6-3 · Conduct remediation actions from monitoring, risk assessment, and open POA&M items
- JSIG Task 6-4 · Update the SSP, SAR, and POA&M
- JSIG Task 6-5 · Report the security status
- JSIG Task 6-6 · Review the reported status: is the risk still acceptable?
- JSIG Task 6-7 · Implement a decommissioning strategy

What this module produces

- A security impact analysis for each proposed or actual change (NIST M-1; JSIG 6-1)
- Ongoing assessment results under the approved monitoring strategy (NIST M-2; JSIG 6-2)
- Remediation and an updated SSP, SAR, and POA&M that keep the original information (NIST M-3, M-4; JSIG 6-3, 6-4)
- Security status reports to the AO, event-driven, time-driven, or both (NIST M-5; JSIG 6-5)
- An ongoing authorization review, with the authorization updated as appropriate (NIST M-6; JSIG 6-6)
- A decommissioning strategy carried out when the system is retired (NIST M-7; JSIG 6-7)

JSIG step outputs Periodic ConMon deliverables; Updated SSP, SAR, POA&M; Updated Security Authorization, as appropriate

WHERE THE JSIG AND NIST DIFFER The steps match task for task. The JSIG is more specific: a security impact analysis that notifies the SCA, updates that keep the original information for oversight and audit, and a

© 2026 Secure By Design Team LLC.

> decommissioning strategy that includes a decommission letter. NIST reports security and privacy posture together.

Learn

12.1 Changes and security impact analysis Analyze a change before it changes the risk.

NIST Task M-1 watches the system and its environment for changes that affect its security and privacy posture. JSIG Task 6-1 makes that a security impact analysis (SIA): determine the impact of a proposed or actual change, notify the SCA, and revise the package as required.

A new component, information flow, dependency, control provider, or threat can undercut the assessment the decision relied on. The size of a technical change doesn't tell you the size of its consequence.

12.2 Assessment, updates, and reporting Assess, respond, update, and report.

The continuous monitoring (ConMon) strategy the AO approved sets which controls are assessed, how often, and by whom; JSIG Task 6-2 assesses a selected subset (NIST M-2). Continuous doesn't mean testing every control constantly.

Results feed remediation and risk response (M-3, 6-3) and updates to the SSP, SAR, and POA&M that keep the original information needed for oversight and audit (M-4, 6-4). The system owner reports status to the AO, event-driven, time-driven, or both (M-5, 6-5).

12.3 Ongoing authorization and disposal Keep the decision current until the system retires.

In NIST Task M-6 and JSIG Task 6-6, the AO (or, in the JSIG, a designee) reviews the reported status to decide whether the risk is still acceptable. If not, the AO decides what follows: new conditions, reassessment, or a new decision.

Disposal closes the loop (M-7, 6-7). The JSIG's decommissioning strategy covers media sanitization, a records retention plan the AO approves, inventory updates, notifications, a review of inherited relationships, and a decommission letter.

Worked example: A change goes through security impact analysis

1. **Change —** A second licensed application is proposed for SBD-APPS01, adding its vendor licensing port to rule F12 for the VLAN 80 workstations.
2. **Impact —** New software and a changed flow: configuration (CM-6, a SCAP Compliance Checker rescan), the vendor's update path (SI-2), its events (AU-2, AU-12), and the course 1.19 recovery set (CP-9).
3. **Decide —** Notify the SCA, reassess before go-live, and give the SIA to the AO or designee, who decides whether it fits the current authorization.
4. **Update —** Update the inventory, SSP, SCTM, rule register, and evidence index, report the change in the next status report, and keep the prior versions.

Build

Run one cycle of the continuous monitoring strategy course 2.1 drafted: the controls assessed, owners, evidence, reporting dates, and escalation triggers. Write a security impact analysis for one proposed change and a status report for the AO.

Practice artifacts Continuous monitoring strategy; Security impact analysis (see Evidence starters)

Think it through

Process a new licensed application on SBD-APPS01 (rule F12), a missed update in one of SBD-WSUS01's rings, and a changed common control such as the server room's badge access: what is reassessed, which records change, what the status report says, and when the AO is engaged. Then list the disposal steps if SBD-WEB01's service were retired, including what depends on it.

Check your understanding

A proposed change adds a port to a documented information flow. What comes first?

- A. Make the change; the current authorization covers future services.
- B. A security impact analysis: identify the affected controls and records, notify the SCA, and follow the required review.
- C. Nothing until the next reauthorization.

Your record

RECORD	YOUR OBSERVATION
Continuous monitoring strategy — location and version	
Security impact analysis — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Monitoring keeps the package true: Splunk review and alerts, updates through SBD-WSUS01 and SBD-REPO01, and the inventory on SBD-MGMT01. A missed update goes to remediation and the status report; a new component starts a security impact analysis.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

COURSE 2.1 / CAPSTONE / ABOUT 4 HOURS

Authorization to Operate package capstone

Assemble and defend the fictional enclave's authorization package. Show where the evidence supports a conclusion, where it does not, and what happens next.

Your submission

1. Authorization package manifest covering the JSIG Task 5-2 minimum and the NIST Task R-1 executive summary, with the scope, registration, and categorization records the package rests on.
2. SSP excerpt with its SCTM, continuous monitoring strategy, and RAR, covering the selected practice objectives.
3. Evidence index, Security Assessment Plan, and SAR excerpt with supported conclusions and visible limitations, including RA-5 scanning coverage.
4. At least two justified findings with POA&M entries and one remediation retest record, with any risk response (RA-7) presented for the AO's acceptance decision (CA-6).
5. Executive risk summary, five-minute AO briefing, a fictional authorization decision record (type, terms and conditions, duration), and one security impact analysis with a status report.

Nine controls, one coherent story

AC-2 · AU-2 · AU-3 · AU-6 · AU-12 · CM-6 · RA-5 · SI-2 · CP-9

Record the exact adopted requirements, parameters, and assessment objectives. This selection is a teaching subset; the actual system baseline follows its governing authority.

Use the logging trail in the Body of Evidence as the model: FND-001, SBD-MGMT01 missing from verified audit collection. Add a second finding from the rest of the scope. RA-5 is a good candidate: the SCAP Compliance Checker and Security Technical Implementation Guide (STIG) results cover configuration, but the network has no credentialed vulnerability scanning, so record that as a gap or limitation, never as a passed test. CM-6, SI-2 (SBD-WSUS01 and SBD-REPO01), and CP-9 (the course 1.19 restore record) offer others. Only the AO can accept risk (CA-6).

Scoring rubric

CRITERION	POINTS	WHAT THE REVIEWER LOOKS FOR
Package completeness and consistency	20	The manifest covers the JSIG 5-2 minimum and the NIST R-1 executive summary; scope, inventory, identifiers, and versions agree.
Traceability	25	Each selected objective links to implementation, evidence, and a conclusion or explicit gap.

CRITERION	POINTS	WHAT THE REVIEWER LOOKS FOR
Assessment quality	20	Methods and observations support conclusions; limitations, including RA-5 scanning coverage, stay visible.
Risk determination and response	20	Risk relates to mission impact; each significant risk has a proposed response, and POA&M actions have owners, dates, and verification criteria.
Decision record and monitoring	15	The briefing is clear; the decision record has a type, terms and conditions, and a duration; the change is analyzed and reported through the right records.

Completion threshold: 80 of 100 points. Revisions are required for unsupported successful assessment claims, inconsistent boundaries, or a claim that the learner granted a real ATO. Course completion is a training outcome; only the AO issues an authorization decision.

The review sequence

- 01 / ASSEMBLE — Reconcile the package: Check the JSIG 5-2 minimum and the NIST R-1 contents, then identifiers, scope, dates, versions, findings, and open actions.
- 02 / DETERMINE — Brief the risk: Explain mission need, significant results, limitations, and the response you propose for each significant risk.
- 03 / DECIDE — Record the decision: The reviewer, acting as AO, questions the evidence and records a fictional ATO, IATT, or DATO with terms, conditions, and a duration.
- 04 / MONITOR — Process the change: Run a security impact analysis, update the affected records, and send the status report the decision asks for.

Reviewer challenges

The SAR has no credentialed vulnerability scan results. Can RA-5 be marked satisfied?

The AO wants operation to start before FND-001 is fixed. What do you bring?

A new service crosses the documented boundary. What must be reviewed?

Evidence starters

Blank starters for the practice artifacts this course produces. Fill them from your own system. The interactive course shows a completed fictional example of each, and the training materials download includes each one as Markdown (and CSV for tables).

System scope record

Prepare outputs Owner: System owner (ISO) with the security team. Agree on the roles, governing direction, mission, boundary, information, early risks, and requirements before the package grows. Module 01 starts it, module 02 completes the Prepare fields, and module 03 adds the categorization basis.

FIELD	YOUR ENTRY
Roles and governing direction — Who holds each role, in NIST and JSIG terms; the governing documents, their editions, and the adopted control release.	
Mission and stakeholders — Missions and business processes the system supports (P-8); everyone with an interest in it (P-9).	
Assets and boundary — Assets to protect (P-10); the authorization boundary the AO determines (P-11), with management paths, shared services, and external dependencies.	
Information types and life cycle — Information the system processes, stores, and transmits (P-12), and each type’s path from creation to disposal (P-13), including boundary transfers.	
Early risk picture — The first system risk assessment (P-14): threats, weaknesses or conditions, likely consequences, and assumptions. Module 04 carries it into the draft Risk Assessment Report (RAR).	

© 2026 Secure By Design Team LLC.

FIELD	YOUR ENTRY
Requirements and allocation — Security and privacy requirements (P-15), the system's place in the architecture (P-16), and where each requirement lands (P-17), including candidate common controls.	
Categorization basis — Method and authority, the information types considered, and where the result is recorded and approved. Completed in module 03.	

The scope record is an exercise starter. The relevant authority determines the formal boundary, categorization, and approval requirements.

System registration

Registration record Owner: System owner (ISO). Register the system with the office the organization or program designates, so it is known, tracked, and accountable before the package grows. NIST registers in Prepare (P-18); the JSIG in Categorize (Task 1-3).

FIELD	YOUR ENTRY
System identity — Name, registration number, owner, and points of contact.	
Registered with — The office the organization designates (NIST P-18) or, for a Special Access Program (SAP) system, the appropriate SAP Service/Agency Authorizing Official (AO) or designee (JSIG Task 1-3).	
Purpose and characteristics — The mission in a sentence or two, location, connections, and operating status.	
Boundary summary — What the authorization covers, with a reference to the documented boundary.	

FIELD	YOUR ENTRY
Categorization and plan status — The approved security categorization, the System Security Plan reference, and the authorization status.	
Update triggers — Changes that require an update to the registration.	

A fictional exercise record. The registering office, the required content, and the format follow the organization’s or program’s policy.

System Security Plan

System description to as-built controls Owner: System owner with the security team and engineers. Describe the system and its categorization, record the plan’s approval, and explain how each selected control is implemented.

FIELD	YOUR ENTRY
System description — Name, identifier, mission, boundary, components, environment, and references (NIST C-1; JSIG 1-2).	
Security categorization — Information types; confidentiality, integrity, and availability impacts with rationale; method; reviewer; approval (C-2, C-3; JSIG 1-1).	
Plan review and approval — Version reviewed, reviewer and role, date, decision, and any conditions (S-6; JSIG 2-4).	
As-implemented control statements — Control ID and adopted revision, approved parameters (from the SCTM), and who does what, where, when, and with which records (I-2; JSIG 3-2).	
Evidence and responsibilities — Evidence identifiers, owners, provider dependencies, and review status.	

FIELD	YOUR ENTRY
Limitations and planned work — Separate what operates from planned work and known gaps.	
Recorded risk decisions — Risk responses, rationale, mitigation, decision owner, and review trigger.	

The example is an excerpt, not a full SSP or a finding of compliance. In the JSIG, the SSP also includes the SCTM, the continuous monitoring strategy, and a Risk Assessment Report; this course keeps them as separate practice artifacts.

Security Controls Traceability Matrix

Requirement to implementation Owner: System owner (ISO) and security team, with implementation owners. Record each selected control's source, tailoring, parameters, allocation, and inheritance, then trace it to implementation, evidence, and results. Started in Select; module 05 adds the as-implemented statements.

CONTROL	SELECTION AND TAILORING	PARAMETERS	ALLOCATION AND INHERITANCE	IMPLEMENTATION AND TRACE
[ID / title / adopted revision]	[Baseline or overlay source; tailoring decision, rationale, approval]	[Organization-defined values and their source]	[System-specific, common, or hybrid; provider and what it supplies; components; owner]	[Planned (module 04), then as implemented (module 05); evidence, result, and finding IDs]

Mappings are instructional. Expand rows to the exact selected control parts and assessment objectives; a single record doesn't prove an entire control. In the JSIG, the SCTM is part of the System Security Plan.

Risk Assessment Report

Risk analysis Owner: System owner (ISO) with the ISSM and ISSO. Record the risks that remain with the selected controls, how likely and harmful each is, and what the assessment must confirm. Drafted in Select as a JSIG Step 2 output; module 08 updates it with assessment results.

RISK	PLANNED SAFEGUARDS	LIKELIHOOD AND IMPACT	RISK LEVEL	RESPONSE AND NEXT UPDATE
[RSK-ID: threat event, the weakness or condition it exploits, and what it affects]	[Selected controls from the Security Controls Traceability Matrix (SCTM) that address it]	[Ratings and reasons, using the authority's method and scale]	[Result, confidence, and assumptions]	[Planned response and owner; what the assessment must confirm (module 08)]

Ratings are exercise values, not an assessment of any real system; use the method and scale your authority directs. In the JSIG's authorization package, the System Security Plan includes a RAR (Task 5-2). Only the AO accepts risk.

Continuous monitoring strategy

Maintain the authorization basis Owner: System owner (ISO) with control owners; approved by the Authorizing Official (AO). Define what is monitored, how often, by whom, and what triggers action, so the authorization basis stays current. Written in Select (S-5; JSIG Task 2-3) and run in module 12.

ACTIVITY	OWNER	FREQUENCY / TRIGGER	EVIDENCE AND ESCALATION
[Monitoring activity and the NIST and JSIG task it serves]	[Role]	[Frequency or trigger approved in the strategy]	[Record produced / threshold / action]

Frequencies and thresholds are dependent on your environment and set by the applicable direction and system risk; this example doesn't prescribe universal intervals. Module 12 runs the strategy and records each security impact analysis.

Master evidence index

Evidence inventory Owner: Evidence custodian and control owners. Make every supporting record retrievable, attributable, current, and traceable to the objectives it supports.

ID	RECORD	SCOPE / OWNER	COLLECTION / VERSION	SUPPORTS
[EV-ID]	[Title and approved location]	[System scope / owner]	[Date / version / reviewer]	[Control, objective, and limits]

© 2026 Secure By Design Team LLC.

This index describes sample records. The referenced technical exports are exercise specifications, not attached operational evidence. Keep superseded versions: the assessment refers to the versions it received.

Security Assessment Plan

Assessment design Owner: Control assessor and system owner. Define who assesses, what they receive, and what will be assessed and how, so the results are defensible.

FIELD	YOUR ENTRY
Assessor and independence — Assessor or team, who selected them, and the independence they provide (NIST A-1).	
Evidence received — Documents and records handed over, with versions, dates, and known exceptions.	
Scope and objectives — System and version, selected controls and objectives, exclusions, assumptions.	
Methods, objects, and expected results — Examine, interview, or test for each objective; objects; coverage and sampling rationale; expected results.	
Responsibilities, schedule, and approval — Assessor, system contacts, dates, and the plan’s review and approval (A-2; JSIG 4-1; CA-2).	
Limitations and safety — Collection limits, access needs, constraints, authorized test conditions.	

Assessment plan is written in full here to avoid confusing its acronym with Special Access Program. In the JSIG, the Security Assessment Plan is made up of the SSP, the SCTM, and the Security Control Assessment Procedures; this excerpt shows the procedures.

Security Assessment Report

Observed assessment results Owner: Control assessor (the JSIG’s security control assessor). Record what was assessed, what was observed, the findings and limitations, and the result of any reassessment.

FIELD	YOUR ENTRY
Assessment basis — Approved plan, scope and version, objectives, dates, assessor.	
Observed results — Actual observation and evidence for each objective; satisfied or other than satisfied.	
Findings — Finding ID, affected scope, requirement and objective, evidence, effect.	
Conclusions and limitations — Supported determinations, missing support, scope limits.	
Recommendations — Corrections the assessor recommends and, in the JSIG, the SCA’s recommended authorization decision.	
Initial remediation and reassessment — What was corrected, the reassessment result, and the original finding kept (A-5; JSIG 4-4).	

The report is a fictional excerpt for practicing traceability and assessment writing. A reassessment adds results to the report; it never removes the original finding.

Plan of Action and Milestones

Accountable corrective action Owner: System owner and remediation owner. Turn an open finding into a risk-ranked, resourced, dated plan that the AO can review and use to monitor progress.

FIELD	YOUR ENTRY
Finding and affected scope — POA&M ID, finding ID, controls and objectives, affected assets.	
Risk and priority — Threat, exposure, mission consequence, current safeguards, uncertainty, and the resulting rank.	

FIELD	YOUR ENTRY
Owner, resources, and milestones — Accountable owner, actions, resources, target dates, dependencies.	
Closure criteria — What must be verified, by whom, and with which record.	
Status and decision — Open or closed, milestone updates, the AO's review, any risk decision reference.	

Milestone tracking and risk acceptance are separate responsibilities. Follow the authority's required POA&M format. FND-002 has no entry because it was fixed and reassessed during the assessment.

Authorization package manifest

Versioned package assembly Owner: System owner and package coordinator. Identify the exact records submitted for the AO's decision, what each one satisfies (JSIG Task 5-2, NIST Task R-1), and whether their scope and versions agree.

PACKAGE COMPONENT	BASIS	IDENTIFIER / VERSION	OWNER	REVIEW CHECK
[Required component]	[JSIG 5-2 / NIST R-1 / AO direction]	[Document ID / version / date]	[Responsible role]	[Required review / status]

The JSIG sets a minimum and the AO can direct more; the applicable authority sets the format and submission path. This manifest does not establish submission or approval.

Executive risk summary

Package executive summary and AO briefing Owner: System owner with risk stakeholders. Give the AO the system, the assessed posture, the significant risk, and the decision requested on one page: the package's executive summary and the basis of the briefing.

FIELD	YOUR ENTRY
System and mission — What the system enables, its boundary and categorization, the authority, and the package version under review.	

FIELD	YOUR ENTRY
Assessment result — Significant supported results, limitations, and the assessor's recommendation, quoted from the SAR.	
Risk to the mission — Consequences, likelihood, uncertainty, existing safeguards, and the significant open findings, consistent with the RAR.	
Proposed response — For each significant risk: mitigate (POA&M actions, conditions), accept, or avoid, with owners and alternatives.	
Decision requested — The decision requested (ATO, IATT, or DATO), the proposed duration, and who is authorized to decide.	

The summary informs the decision; it doesn't make it. Keep recommendations separate from the AO's recorded decision and its conditions.

Authorization decision document

Fictional decision exercise Owner: Authorizing official (played by the reviewer). Practice recording what an AO's decision contains: the decision, its terms and conditions, its duration, and what monitoring must report.

FIELD	YOUR ENTRY
System and scope — System name, boundary, and the package version the AO reviewed.	
Decision — ATO, IATT, or DATO (JSIG); NIST also names authorization to use, common control authorization, and denial. Who decided, and when.	
Terms and conditions — What must be done, maintained, or limited for the decision to stand, and who is responsible.	

FIELD	YOUR ENTRY
Duration — Time-driven (an end date) or ongoing authorization backed by robust continuous monitoring, and the events that trigger an earlier review.	
Monitoring and reporting — What the system owner reports, when (event-driven, time-driven, or both), and to whom.	
Authority and signature — Who signed, under which authority, and what the record is not.	

Exercise material only. A real authorization decision document is issued and signed by the appointed AO under the governing authority; nothing in this course grants an ATO, IATT, or DATO.

Security impact analysis

Change impact record Owner: System owner with the ISSM and ISSO. Decide what a proposed or actual change does to the security posture before it goes ahead: which controls and records it touches, what must be reassessed, and who must be told (NIST M-1, JSIG 6-1).

FIELD	YOUR ENTRY
Change — Change ID, what changes and why, requester, proposed date, affected components and information flows.	
Security impact — Affected controls, implementations, and evidence, and the effect on each: better, worse, or unknown.	
Determination — Significant or not, and why; what must be reassessed; whether the boundary or categorization changes.	
Notifications and approvals — Who is told or must approve before the change: SCA, ISSM, change board, AO or designee.	

FIELD	YOUR ENTRY
Records to update — Which package records change, who updates them, and which versions are kept.	
Outcome — Approved, deferred, or rejected; the reassessment result; date closed; the status report that carried it.	

The authority’s change process decides who approves a change and when the AO must be engaged. The example is a fictional change to the practice system.

Knowledge check answers

01 Your program directs the public JSIG of 11 April 2016. Which statement fits it?

C. It follows SP 800-37 Revision 1's six steps, starting at Categorize, with SP 800-53 Revision 4 and CNSSI 1253. NIST is the foundation; the JSIG is SAP-specific direction for applying it. The 2016 edition predates the Revision 2 Prepare step and the Revision 5 controls, and your program may direct a successor.

02 Your program follows the 2016 JSIG, which has no Prepare step. Where does the boundary and registration work happen?

A. In Categorize: describe the system and its boundary (Task 1-2), then register it (Task 1-3). The JSIG follows SP 800-37 Revision 1, so work that NIST Revision 2 puts in Prepare (P-11, P-18) appears in the JSIG's Categorize step.

03 The system owner has categorized the system and wants to start selecting controls. What does NIST SP 800-37 Revision 2 call for first?

B. Review and approval of the categorization by the authorizing official or a designated representative (C-3). The system owner and information owner categorize (C-2); approval is a separate task (C-3). In the JSIG, the categorization is documented in the draft SSP (Task 1-1), and the plan is approved in Select (Task 2-4).

04 A facility office says physical access to the server room is "covered." What does the SCTM need before the plan goes for approval?

C. The provider, the parts it performs, its assessment information, and what the system team still does. An inherited or hybrid allocation needs an identified provider and applicable evidence. Record the split in the SCTM so the assessor knows what to ask of whom.

05 The engineers built the log path differently from the approved plan. What does the Implement step call for?

B. Update the SSP and SCTM to the as-implemented state. NIST Task I-2 and JSIG Task 3-2 record the controls as actually implemented. The assessor tests that record, so it has to match the system.

06 A configuration scan reports no open findings, but one in-scope server is missing from its results. What does the scan support?

C. A clean result for the servers it covered; the missing server is a coverage gap to record and close. A result supports only the scope it covered. Keep it, record the gap, and collect the missing evidence before anyone relies on the result.

07 The engineer who built the logging pipeline offers to assess it. What is the problem?

A. An assessor should not assess their own work; the AO sets the independence required. Independence keeps the result credible. The engineer still takes part, as someone the assessor interviews and observes.

08 During the assessment, the team fixes a finding and the reassessment passes. What happens to the original finding in the SAR?

B. It stays, with the remediation and the reassessment result beside it. Initial remediation (NIST A-5, JSIG 4-4) adds the reassessment to the report; it does not erase what the assessment found. Findings that remain open go to the POA&M.

09 Does adding a finding to the POA&M mean its risk has been accepted?

C. No. Only the AO accepts risk, as part of the authorization decision. The POA&M plans and tracks corrective action. Accepting the remaining risk is a separate decision that belongs to the AO.

10 Your authority follows the JSIG. What must the authorization package contain at a minimum?

C. The SSP (with its SCTM, continuous monitoring strategy, and RAR), the SAR, and the POA&M, plus any evidence the AO directs. That is the JSIG Task 5-2 minimum. NIST Task R-1 adds an executive summary and puts privacy plans and assessment reports alongside the security ones.

11 The AO will allow operation while an open finding is fixed. What must the decision document record?

A. The decision, the terms and conditions tied to that finding, and the duration. The decision document carries the decision, its terms and conditions, and its duration. A POA&M tracks corrective work; accepting the risk is the AO's decision.

12 A proposed change adds a port to a documented information flow. What comes first?

B. A security impact analysis: identify the affected controls and records, notify the SCA, and follow the required review. NIST Task M-1 and JSIG Task 6-1 evaluate a change against the assessed and authorized scope before it quietly changes the risk.

Reviewer challenge guidance

The SAR has no credentialed vulnerability scan results. Can RA-5 be marked satisfied? No. SCAP Compliance Checker and STIG results show configuration compliance, not vulnerability scanning coverage. Record the gap as a limitation or finding, carry it into the RAR and the executive summary, and let the AO weigh it. Plan its assessment for when a credentialed scanning capability exists, and bring that capability in through a security impact analysis.

The AO wants operation to start before FND-001 is fixed. What do you bring? The risk in mission terms, the safeguards already in place, PM-001's milestones and verification, and proposed terms and conditions, such as a recorded interim review of SBD-MGMT01's local Security log. Present them as proposals: the AO decides whether to accept the risk with conditions, wait, or deny. An IATT isn't the answer; it covers testing, not operation. Record the outcome in the decision record, not in the POA&M.

A new service crosses the documented boundary. What must be reviewed? Run a security impact analysis: identify the new information flow, owner, data, dependencies, and protection requirements. Revisit the boundary and categorization assumptions, determine the affected controls, notify the SCA, and update the architecture, SSP, evidence, assessment, and risk records. The AO or designee decides whether the change still fits the current authorization.

Sources

Choose the applicable authority and record the adopted versions before using a template. Module reference numbers correspond to these documents.

[1] NIST SP 800-37 Revision 2

RMF lifecycle, tasks and outputs, authorization package, roles, and monitoring. See Chapter 3 and Appendix E.

[2] NIST SP 800-53 Revision 5

Security and privacy control catalog. Record the release adopted by the governing authority.

[3] NIST SP 800-53A Revision 5

Control assessment procedures and examine, interview, and test methods.

[4] NIST SP 800-53B

Control baselines, tailoring, and overlays. Apply the appropriate system context.

[5] DoDI 8510.01

Risk Management Framework for DoD Systems, July 19, 2022.

[6] DoDM 5205.07

Special Access Program Security Manual, January 17, 2025.

[7] DCSA Voice of Industry · September 2025

DCSA newsletter for cleared industry on the DAAG transition. Confirm the current guide, version, and effective date with DCSA.

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

The six RMF steps, tasks, and outputs for Special Access Program (SAP) systems, built on NIST SP 800-37 Revision 1, SP 800-53 Revision 4, and CNSSI 1253 (March 2014). Confirm whether your program directs it or a successor.

© 2026 Secure By Design Team LLC.

Course review and sign-off

Before moving on, confirm each module left its outputs behind — and that what remains open is written down.

Module completion

MODULE	OUTPUTS FILED	DATE
01 RMF roles, steps, and editions	☐ yes	
02 Define and register the system	☐ yes	
03 Describe and categorize the system	☐ yes	
04 Select controls and plan monitoring	☐ yes	
05 Implement and document the controls	☐ yes	
06 Connect implementation to proof	☐ yes	
07 Prepare the assessment	☐ yes	
08 Perform and report the assessment	☐ yes	
09 Build the plan of action and milestones	☐ yes	
10 Assemble the authorization package	☐ yes	
11 Support the authorization decision	☐ yes	
12 Monitor and maintain authorization	☐ yes	
Capstone Authorization to Operate package	☐ yes	

Open items carried forward

© 2026 Secure By Design Team LLC.

Next in the learning path

That completes Risk Management Framework. Course 2.2, Body of Evidence, implements and assesses the controls you selected, starting from these outputs.

> **KEEP IT HONEST** Course completion records learning activity. It is not a system authorization, an assessment result, or an approval by any authorizing official. Exercise records are fictional.